

GRC 101 LAB REPORT (WEEK 2)

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Introduction to GRC Engineering
Date Submitted	25 July, 2026

NexaLearn GRC Assessment Report

1. Introduction

NexaLearn Digital Services Limited is a Nigerian ed-tech company that provides online training, digital assessments and certification to about 18,000 learners. Around 600 of these learners are based in the European Economic Area (EEA). The company is growing quickly, and the Board wants to increase active learners by 40% within one year. It also plans to introduce an AI-assisted admissions screening tool within three months.

However, there are already some security and governance concerns that need attention. These include the use of shared administrator accounts, a former contractor's account that remained active for 37 days after they left, a cloud storage container that was temporarily made public, and a customer-support vendor contract that does not properly address data protection requirements.

This assessment looks at NexaLearn's stakeholders, objectives, compliance obligations, key risks, governance structure and controls. It also considers the results of the control testing and recommends priorities for the next 90 days. The main aim is to help NexaLearn continue growing while making sure that security, privacy and compliance risks are properly managed.

2. Context, Stakeholders and Objectives

Before looking at NexaLearn's risks, it is important to understand the different people and groups that have an interest in how the organisation operates. Internally, the Board is focused on growth and maintaining trust. IT is responsible for keeping systems working effectively, while Finance handles areas such as refunds and reconciliation. HR manages employees and contractors, and Internal Audit provides independent checks on whether controls are working as expected.

Externally, NexaLearn has about 18,000 learners who depend on its services. The organisation also has regulators, a payment gateway provider, a customer-support vendor that handles learner information and an outsourced development vendor that has access to the company's codebase.

These stakeholders do not always have the same priorities. For example, management wants the AI-assisted admissions screening tool to be launched within three months, but proper governance around the tool requires risk assessment, human oversight, bias testing and clear

accountability. Rushing the system could lead to unfair or inaccurate admissions decisions, while delaying it could affect the growth plans already approved by the Board. This is where GRC becomes important because the aim is not simply to choose security over growth or growth over security. The aim is to make sure that the risks are properly assessed and that management makes an informed decision before the system is deployed.

There is also a conflict between convenience and accountability in privileged access. Three technical staff currently use a shared emergency administrator account with a temporary MFA exemption. Although this may seem convenient, it makes it difficult to know exactly who performed an action. Individual administrator accounts with MFA and a properly controlled break-glass account would provide better accountability.

Another conflict exists with vendor onboarding. NexaLearn wants to onboard vendors quickly to support its growth, but vendors that handle learner information should go through proper due diligence and contract review before they start processing data.

NexaLearn's main objectives are to grow its active learner base by 40% within 12 months, maintain trust, achieve 99.9% availability for learner-facing services, meet its compliance objectives and introduce the AI-assisted admissions screening tool with appropriate human oversight.

Its critical processes include learner onboarding and admissions, online learning delivery, digital assessments and certification, payment processing, customer support, user access management and incident response. Important information assets include learner personal data, identity documents, employee records, payment-related information and authentication credentials. The organisation also depends on cloud services, Microsoft 365, a payment gateway, a third-party customer-support platform and an outsourced software-development vendor.

3. Compliance Obligations

NexaLearn needs to consider a number of legal, regulatory, industry and voluntary requirements.

The Nigeria Data Protection Act (NDPA) 2023 is clearly relevant because NexaLearn operates in Nigeria and processes personal data belonging to learners, employees and other individuals. The organisation therefore needs appropriate controls to protect this information and manage privacy risks.

The General Data Protection Regulation (GDPR) may also apply because approximately 600 learners are located in the EEA. However, its exact applicability should be confirmed based on whether NexaLearn is offering services to or monitoring individuals in the EEA rather than assuming that it applies automatically.

PCI DSS is relevant because NexaLearn processes payments. However, the exact scope depends on how payment card information is handled and how responsibilities are divided between NexaLearn and its payment gateway provider.

ISO/IEC 27001 is a voluntary certifiable standard that is relevant to NexaLearn because the organisation is working towards demonstrating readiness for an ISO/IEC 27001 certification programme. ISO/IEC 42001 is also relevant because of the planned AI-assisted admissions screening tool and the need for proper AI governance, risk management and human oversight.

NIST CSF 2.0 is another useful voluntary framework that can help NexaLearn organise its cybersecurity risk management activities across its systems, cloud environment and third

parties. These requirements should be reviewed regularly as the organisation grows and its technology environment changes.

4. Risk Assessment and Risk Appetite

Ten risks were identified from the scenario and the evidence provided. Six were rated Critical at the inherent level, while the remaining risks were rated High. The main concerns include unauthorised access caused by shared administrator accounts and delayed offboarding, exposure of learner information through incorrect cloud storage permissions, weaknesses in the customer-support vendor contract and risks connected to the planned AI admissions system.

Three of the identified risks are directly related to third parties. The customer-support vendor processes learner information but does not have detailed data-processing requirements or a defined breach-notification timeframe in its contract. The outsourced development vendor also creates risks around software development and change management because it has access to NexaLearn's codebase. The payment gateway relationship creates a further risk, since it is not yet fully confirmed how payment security responsibilities are divided between NexaLearn and the provider.

The planned AI-assisted admissions screening tool is another important risk. If the system is introduced without proper governance, human oversight and monitoring, it could make inappropriate or unfair admissions decisions. The organisation therefore needs to complete a proper risk assessment and establish clear accountability before the tool is deployed.

NexaLearn has a low risk appetite for security breaches, privacy violations and regulatory non-compliance because these could damage learner trust and expose the organisation to serious consequences. Its appetite for availability is low to moderate because some planned disruption may be accepted for necessary security work, but the 99.9% availability target means major outages are not acceptable.

The organisation has a moderate appetite for innovation. This means NexaLearn can take on some level of risk when introducing new technology such as AI, but this should only happen where appropriate governance, human oversight and monitoring are in place.

Most of the identified risks should be treated through risk reduction. Risks that remain above the organisation's appetite should not simply be accepted without formal management approval and documented justification.

5. Governance, Ownership and Segregation of Duties

NexaLearn's risk management responsibilities should follow the three lines model. The first line includes teams such as IT, HR, Finance and business management that own and manage risks as part of their daily activities. The second line includes GRC, Privacy/Legal and AI Governance functions, which provide guidance, monitoring and challenge. Internal Audit acts as the third line by providing independent assurance over governance, risk management and controls.

A RACI structure was used to assign responsibility across areas such as access management, incident response, privacy compliance, third-party risk, AI governance, payment security, business continuity and internal audit review. Executive Management is accountable for major decisions, while operational teams are responsible for carrying out the relevant activities. GRC provides oversight and advice, and Internal Audit remains independent.

One segregation-of-duties issue identified in the evidence relates to Finance. The Finance Officer currently has access to both approve payment refunds and reconcile the related transactions. This creates a risk because the same person could approve a refund and then reconcile it without an independent person checking whether the transaction was appropriate. The recommended approach is to separate these duties between different people. Where this is not possible, high-value refunds should require independent review and approval.

6. Common Control Framework

NexaLearn's Common Control Framework contains 15 controls covering areas such as access control, privileged access, cloud security, third-party management, incident response, privacy, payment security, AI governance, secure software development, change management, business continuity, logging and monitoring, security awareness and risk and compliance management.

The controls are mapped to relevant risks and applicable frameworks or obligations, including ISO/IEC 27001, NIST CSF 2.0, NDPA 2023, GDPR, ISO/IEC 42001 and PCI DSS, depending on the control. Each control has an owner, review frequency and evidence requirements. This is important because a control should not only exist as a policy on paper; there should also be evidence that it is operating effectively.

The current control environment still has weaknesses. Privileged access management and cloud storage access controls require improvement. Third-party management is also weak because the customer-support vendor's contract does not contain sufficient data protection and breach-notification requirements. Some other controls, including access management, incident response, privacy, payment security and business continuity, are partially implemented. AI governance and security awareness activities are currently planned.

NexaLearn also relies on cloud and SaaS providers, meaning that some security controls are inherited from suppliers. However, this does not remove NexaLearn's responsibility. The organisation remains responsible for secure configuration, access management, data protection, monitoring and vendor oversight. It should also review appropriate assurance information from its suppliers rather than assuming that inherited controls are automatically sufficient.

7. Control Testing and Findings

Three control tests were carried out using the evidence provided.

The first test focused on user access and privileged account management. The evidence showed that three technical staff share an emergency administrator account and that a former contractor's account remained active for 37 days after the contract ended. The access review process therefore has both design and operating effectiveness concerns. The design is not strong enough to prevent shared administrator access and weaknesses in offboarding, while the operating effectiveness is also poor because the former contractor's account remained active for such a long period. NexaLearn should remove shared administrator accounts, introduce individual privileged accounts with MFA and strengthen its joiner-mover-leaver process.

The second test focused on incident detection, escalation and breach response. The evidence included an impossible-travel alert, a change in cloud storage permissions from private to public and the download of approximately 1,240 learner records from an unfamiliar IP address. Although public access was later disabled and the privileged password was reset, executive management was only informed at 13:15, and no regulator or affected learner had been notified at that point. The incident response process also did not clearly define escalation criteria or regulatory notification procedures. NexaLearn should therefore establish clear escalation

requirements, define its regulatory notification process and carry out regular incident response exercises.

The third test reviewed the customer-support vendor. The vendor processes learner information, including names, contact details, support conversations and limited identity documents. However, the contract does not contain detailed data-processing requirements or a 24-hour incident-notification obligation. The vendor also provided a SOC 2 Type II report, but there was no evidence that NexaLearn reviewed the exceptions identified in the report. NexaLearn should strengthen the contract, complete documented vendor due diligence and review the available assurance evidence.

The results of these tests show a common problem. NexaLearn has processes and controls in place, but they are not always being followed, tested or monitored effectively.

8. Dashboard and 90-Day Improvement Roadmap

The GRC dashboard should help management track whether key risks and controls are improving. The indicators should cover areas such as privileged accounts without individual assignment or MFA, accounts not deactivated within the required timeframe, publicly accessible cloud storage, overdue risk treatment actions, vendor contracts missing data protection clauses, incident response exercises and controls rated as not effective.

Each indicator should have a named owner, target or threshold, data source and reporting frequency. This will allow management to identify problems early and take action instead of waiting for the next formal assessment.

The first 30 days should focus on the most urgent access and incident response issues. NexaLearn should remove shared administrator accounts, strengthen access reviews, improve the offboarding process and define clear incident escalation procedures.

Between days 31 and 60, the focus should move to cloud storage permissions, privacy controls, third-party vendor contracts and AI governance. The customer-support vendor contract should be updated, and the AI governance framework should be established before the admissions screening tool is deployed.

Between days 61 and 90, NexaLearn should strengthen secure software development and change management and improve its business continuity and disaster recovery arrangements. GRC should also review the Risk Register and Common Control Framework to confirm that actions are being completed and that unresolved risks are properly tracked.

9. Conclusion

The assessment shows that NexaLearn has several GRC processes and controls in place, but there are still important weaknesses that need to be addressed. The main concerns are around access management, incident response, third-party risk, privacy and cloud security. The planned AI-assisted admissions system also creates a new area of risk that needs proper governance before deployment.

The control testing showed that having a process in place does not automatically mean that the process is effective. The shared administrator account, delayed contractor offboarding, weaknesses in the vendor contract and unclear incident response procedures all show gaps between what should happen and what is actually happening.

The most important next step is therefore to focus on the 90-day improvement plan and make sure that each action has clear ownership and is monitored until completion. NexaLearn does not necessarily have to choose between growth and security. Instead, it needs to build a GRC approach that can keep up with its growth and ensure that important decisions, including the

introduction of AI, are properly assessed before they create bigger problems. This will allow the organisation to continue pursuing its growth and innovation objectives while managing the risks that come with them.